

Distribution-free control-adequacy certificates on the MITRE ATT&CK kill chain

2026-09-20 (working note, version 0.1.0)

Abstract

We ask a decision question with a real, curated attack model rather than a synthetic one: which portfolios of defensive controls *provably* keep a ransomware operation’s reachability to its impact objective below a chosen level, when the effectiveness of each control is only known within an interval? Using the pinned MITRE ATT&CK Enterprise knowledge base (v17.1; 588 techniques, 44 mitigations, and their real *mitigates* edges), we define a monotone kill-chain reachability function and certify portfolios by evaluating it at the adverse and favourable corners of the effectiveness uncertainty set — the necessary/possible interval-efficiency argument, applied to attacker reachability. The guarantee is distribution-free and holds for every parameter value in the set. We report a cost-versus-guarantee frontier, a set of realistic named bundles, and how the minimum certifiable portfolio size grows with assumed uncertainty. The contribution is the method and its application to real ATT&CK structure; effectiveness intervals are analyst priors, not incident measurements, and no claim is made about any specific organisation.

1 Model

A ransomware operation traverses the ordered post-compromise ATT&CK tactics from initial access to exfiltration and then the impact objective T1486 (Data Encrypted for Impact). A control portfolio is a set of ATT&CK mitigations. Each technique’s residual per-attempt success is $\text{base} \cdot \prod_m (1 - \text{eff}_m)$ over the portfolio mitigations that mitigate it. A stage’s success is the usage-weighted mean residual over its techniques (weights are the real ATT&CK procedure-usage counts, so a prevalent technique matters more and partial coverage helps proportionally); the impact stage contributes the objective technique alone. Reachability R is the product of stage successes. R is coordinatewise monotone: increasing in every base rate and decreasing in every eff_m .

2 Certificate

Effectiveness is uncertain, so each $\text{eff}_m \in [e_m^{\text{lo}}, e_m^{\text{hi}}]$ and the base rate lies in a common interval. Monotonicity places the extremes of R at the box corners. A portfolio is *guaranteed* adequate at level ε when $R \leq \varepsilon$ at the worst corner (base high, every effectiveness low), and only *possible* when $R \leq \varepsilon$ merely at the best corner. This is exactly the necessary/possible efficiency corner argument used elsewhere in this repository, here applied to reachability; where incident counts exist, finite-sample betting bounds supply the intervals.

Table 1: Greedy worst-case-reduction frontier (first eight additions): mitigation added and worst-case reachability after it, percent.

Size	Mitigation	Name	Worst R (%)
1	M1032	Multi-factor Authentication	9.8
2	M1031	Network Intrusion Prevention	5.9
3	M1040	Behavior Prevention on Endpoin	3.6
4	M1026	Privileged Account Management	2.3
5	M1018	User Account Management	1.5
6	M1047	Audit	1.0
7	M1038	Execution Prevention	0.7
8	M1017	User Training	0.6

Table 2: Named control bundles: size, worst-case reachability, and adequacy certificates.

Bundle	Size	Worst R (%)	Guar. $\leq 10\%$	Guar. $\leq 5\%$
identity	4	3.4	yes	yes
backup	1	22.6	no	no
segmentation	1	23.6	no	no
patching	1	23.5	no	no
detection	2	15.2	no	no
hospital core	5	3.4	yes	yes

3 Results

With a common base-rate prior $[0.5, 0.9]$ and a wide effectiveness prior $[0.20, 0.70]$ (multi-factor authentication tightened to $[0.85, 0.99]$ from the reported account-compromise reduction), the undefended worst-case reachability is 28.2%. Along the greedy cost-versus-guarantee frontier, 1 mitigation guarantees $R \leq 10\%$, 3 guarantee $R \leq 5\%$, and 6 guarantee $R \leq 1\%$ (Table 1). Among 6 realistic named bundles, 2 are guaranteed adequate at 5%: the identity bundle (worst case 3.4%) and the hospital-core bundle (3.4%), whereas data backup alone leaves 22.6% (Table 2). Identity controls are the dominant lever; single controls from other families do not certify even $R \leq 10\%$.

4 Sensitivity to assumed uncertainty

The certificate’s demands scale with ignorance. To guarantee $R \leq 5\%$, a narrow effectiveness prior $[0.35, 0.55]$ needs 2 mitigations, while a wide prior $[0.10, 0.85]$ needs 10 (with undefended worst case 28.2%). This is the intended behaviour: a distribution-free guarantee buys robustness at the price of demanding more coverage when less is known.

5 Limitations

ATT&CK’s `mitigates` edges are qualitative expert mappings, not measured effect sizes; the effectiveness intervals are analyst priors, with one evidence-tightened exception, and the kill-chain progression is a modelling abstraction. There is no validation against real incidents. The result is

a method and its application to real ATT&CK structure with explicit uncertainty handling — a decision-support certificate, not an empirical estimate of any organisation’s risk.

Data and reproducibility. MITRE ATT&CK Enterprise v17.1 is used unmodified under the ATT&CK Terms of Use; the pinned bundle is hashed and all outputs carry a provenance manifest. Every number above is generated from the committed result tables.